Passwörter und Zwei-Faktor – einfach sicher

Nach den Wechselrezepten „Passwörter“ und „Authenticator“
vom Digital Independence Day (di.day)

Quellen: [1] di.day Passwörter · [2] di.day Authenticator

Über mich

DIDAY

>_

Bartosz

bmmmm



Teil von bitcircus101

Offener Hackspace in Bonn · bitcircus101.de



Mitglied im Datenburg e.V.

Bonner Chaostreff und Hackspace · datenburg.org

I like computers & bikes

Tüfteln am Rechner, unterwegs auf dem Rad.

Nutze selbst

iCloud-Schlüsselbund, Bitwarden und 2FAS

Quellen: [3] bitcircus101.de · [4] datenburg.org



Ratet mal: Was ist das häufigste Passwort in Deutschland?

Einfach reinrufen!

Quellen: [5] HPI Passwörter 2025

Auflösung: die häufigsten Passwörter 2025

Die meist geleakten Passwörter in Deutschland, ausgewertet vom Hasso-Plattner-Institut.

1.	2.	3.	4.	5.
`123456`	`123456789`	`565656`	`12345678`	`hallo123`

Weiter unten: `kaffeetasse` (6) · `1234567` (7) · `passwort` (8) · `lol123` (9)

Das HPI rät: über 15 Zeichen, nie dasselbe Passwort zweimal, ein Passwortmanager und Zwei-Faktor – genau darum geht es heute.

Quellen: [5] HPI Passwörter 2025

Stimmungsbild: Hand hoch, wer …

Kurz zum Warmwerden – es gibt kein Richtig oder Falsch.

… einen Passwort-manager nutzt

Auch der im Browser oder auf dem Handy zählt.

… ein Passwort mehrfach benutzt

Ganz ehrlich – das machen viele.

… Zwei-Faktor schon nutzt

Bei mindestens einem Konto, per App oder Code.

… einen Passkey kennt

Noch nie gehört? Auch gut – kommt im Ausblick.

Jede Hand ist okay – genau für diese Fragen ist der Vortrag da.

Quellen: [1] di.day Passwörter · [2] di.day Authenticator

Was wir heute besprechen

1

Das Problem

Ein Passwort für alles – und warum das schiefgeht.

2

Passwort-manager

Drei Stufen, Umzug, Master-Passwort, E-Mail-Aliase.

3

Zwei-Faktor

Der zweite Schlüssel vom Handy und die passende App.

4

Ausblick

Passkeys und deine Hausaufgabe.



5

Live-Demo

Bitwarden im Einsatz: Leck-Check, Phishing, Zwei-Faktor.

Quellen: [1] di.day Passwörter · [2] di.day Authenticator

Das Problem: ein Passwort für alles

Viele nutzen dasselbe Passwort für viele Konten. Das geht so lange gut, bis …



1 Passwort

zum Beispiel „Sommer2024!“ – steht 678-mal in Datenlecks



20 Konten

E-Mail, Bank, Shops, Social Media …



1 Datenleck

Ein einziger Shop wird gehackt.



Alles offen

Angreifer probieren das Passwort automatisch überall aus.



Die Lösung: Für jedes Konto ein eigenes Passwort – und ein Werkzeug, das sie sich für dich merkt.

Quellen: [6] BSI Passwörter · [7] OWASP · [8] Have I Been Pwned

Jeder Passwortmanager ist besser als keiner

Browser, Handy, Computer oder eigene App – Hauptsache, du fängst an.

Auch das BSI sagt: „Aus Sicht des BSI überwiegt der Nutzen bei weitem.“ (9. Dezember 2025)

Quellen: [9] BSI Pressemitteilung

Was macht ein Passwortmanager?

Stell ihn dir vor wie einen Tresor für alle deine Passwörter.



Merkt sich alles

Alle Passwörter an einem Ort – verschlüsselt.



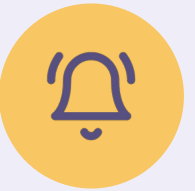
Erfindet Passwörter

Lang, zufällig und für jedes Konto anders.



Füllt automatisch aus

Kein Abtippen, kein Zettel am Bildschirm.



Warnt dich

Viele melden schwache, doppelte oder gehackte Passwörter.



Du merkst dir nur noch **ein einziges** Passwort – oder entsperrst einfach mit Fingerabdruck oder Gesicht.

Quellen: [10] BSI Passwort-Manager · [11] Chrome-Hilfe · [12] Firefox-Hilfe · [13] Google Passwortcheck · [14] Apple Passwörter · [15] Apple iPhone

Drei Stufen – jede ist ein Gewinn

Du musst nicht oben anfangen. Jede Stufe macht dich sicherer – je höher, desto unabhängiger von einem einzelnen Konzern.



Ohne

Zettel und ein Passwort für alles

Stufe 1

Browser

Chrome, Firefox, Safari, Edge

Stufe 2

Betriebssystem

Apple, Google, Windows, Linux

Stufe 3

Eigene App

Bitwarden, KeePassXC, Proton Pass

Quellen: [1] di.day Passwörter · [6] BSI Passwörter

Stufe 1: der Browser

Schon eingebaut – du musst nur „Ja“ sagen.



Chrome, Firefox, Safari und Edge fragen nach dem Anmelden: „Passwort speichern?“

Einfach zustimmen – und beim nächsten Konto ein vorgeschlagenes, starkes Passwort nehmen.

Guter Anfang!

Gut

- Schon da und kostenlos
- Speichern mit einem Klick
- Abgleich über dein Konto auf allen Geräten

Aber (di.day, BSI)

- Du hängst an einem Browser und seinem Konzern
- Der Anbieter sieht, welche Dienste du nutzt
- Schadsoftware kann sie leichter auslesen

Quellen: [1] di.day Passwörter · [10] BSI Passwort-Manager · [11] Chrome-Hilfe · [12] Firefox-Hilfe · [14] Apple Passwörter · [16] Edge Sync

Stufe 2: das Betriebssystem

Eingebaut in Handy und Computer – bequem, vor allem in der eigenen Gerätewelt.

iCloud-Schlüsselbund

App „Passwörter“ auf iPhone, iPad und Mac, über iCloud für Windows auch am PC. Face ID, Ende-zu-Ende-verschlüsselt.

Google Passwortmanager

In Android und Chrome eingebaut. Prüft, ob deine Passwörter in einem Datenleck aufgetaucht sind.

Windows und Edge

Passwörter liegen im Microsoft-Konto und werden in Edge abgeglichen. Der Kennwortmonitor warnt bei Datenlecks.

Linux-Schlüsselbund

GNOME-Schlüsselbund oder KDE Wallet speichern Passwörter für Programme, z. B. für Chrome. Für Webseiten: KeePassXC oder Bitwarden dazu.

Quellen: [13] Google Passwortcheck · [14] Apple Passwörter · [15] Apple iPhone · [16] Edge Sync · [17] Apple iCloud · [18] iCloud Windows · [19] Edge Kennwortmonitor · [20] Chromium · [21] GNOME Keyring · [22] KDE Wallet

Stufe 3: eigene Passwortmanager-Apps

Laufen auf allen Geräten – unabhängig vom Hersteller deines Handys.

Bitwarden

Open Source **Gratis-Version** **alle Geräte**

Firma in den USA. Daten wahlweise in der EU-Cloud oder auf dem eigenen Server (Vaultwarden).

KeePassXC

Open Source **kostenlos** **ohne Cloud**

Eine verschlüsselte Datei – bei dir. Handy: KeePassDX (Android), KeePassium (iPhone). Abgleich z. B. per Syncthing oder Nextcloud.

Proton Pass

Open Source **Schweiz** **Gratis-Version**

Gleicht verschlüsselt über die Proton-Cloud ab. Apps für Handy, Computer und Browser.

Auch bei di.day genannt: Sticky Password, 1Password, Dashlane. Nicht empfohlen: LastPass.

Quellen: [1] di.day Passwörter · [23] bitwarden.com · [24] Bitwarden EU-Region · [25] Vaultwarden · [26] keepassxc.org · [27] Proton Pass

Bitwarden-Konto anlegen: EU-Server wählen

Bei der Registrierung „bitwarden.eu“ auswählen – dann liegen deine Daten in der EU.



1 **Server „bitwarden.eu“ wählen**

Steht beim Registrieren direkt bei der E-Mail-Adresse. Die andere Wahl: bitwarden.com (USA).

2 **E-Mail bestätigen**

Bitwarden schickt einen Link – in der Mail auf „Verify email“ klicken.

3 **Master-Passwort festlegen**

Lang und merkbar. Auf Wunsch prüft Bitwarden es gegen bekannte Datenlecks.

⚠ **Das Konto gibt es nur auf diesem Server.** Auch beim Anmelden in App und Browser „bitwarden.eu“ wählen. Später wechseln geht nur per Export und Import.

Quellen: [24] Bitwarden EU-Region · [28] Bitwarden-Konto

Umziehen in vier Schritten

So kommst du vom Browser oder alten Manager in eine neue App – in etwa 30 Minuten.

1

App aussuchen

Installieren – am besten zuerst auf dem Handy.

2

Master-Passwort festlegen

Lang und merkbar. Auf Papier an einem sicheren Ort aufheben.

3

Passwörter umziehen

Im Browser als CSV-Datei exportieren und in der neuen App importieren.

4

CSV-Datei löschen!

Darin stehen alle Passwörter lesbar. Auch aus dem Papierkorb löschen.

Tipp: Ab und zu ein Backup auf USB-Stick oder externe Festplatte. Danach: Zwei-Faktor einschalten – dazu gleich mehr.

Quellen: [1] di.day Passwörter

Das Master-Passwort: lang schlägt kompliziert

Das BSI sagt: „Je länger, desto besser.“ Ab 25 Zeichen darf ein Passwort einfach sein.

schlecht

`P@ssw0rt!`

Sieht kompliziert aus – steht aber schon 42-mal in Datenlecks.

gut

`tulpe-fahrrad-mond-kaffee-wolke`

5 zufällige Wörter, 31 Zeichen – lang und gut zu merken.

5 bis 6 zufällige Wörter, getrennt durch Leerzeichen oder Bindestriche

Nur für den Passwortmanager benutzen – nirgendwo sonst

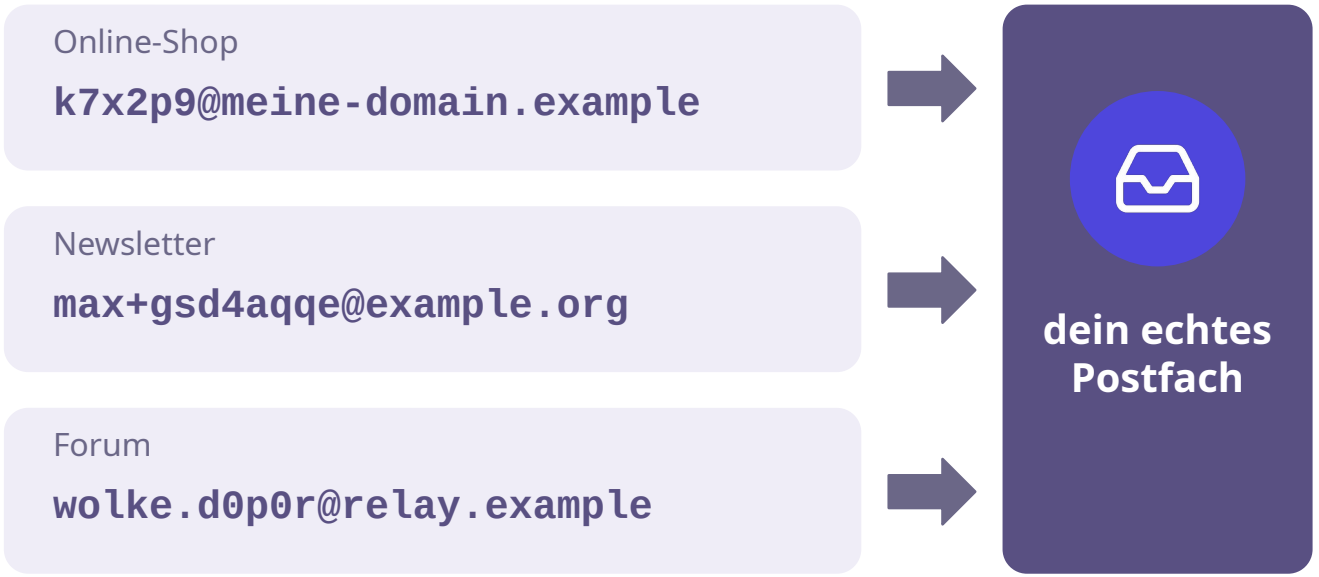
Auf Papier aufschreiben und sicher verwahren

Die Beispiele bitte nicht übernehmen – denk dir eigene Wörter aus.

Quellen: [1] di.day Passwörter · [6] BSI Passwörter · [8] Have I Been Pwned

Extra: eine E-Mail-Adresse pro Konto

Der Passwortmanager erfindet nicht nur Passwörter – auf Wunsch auch E-Mail-Adressen (Aliase).



Echte Adresse bleibt privat

Der Dienst sieht nur den Alias.

Spam? Alias abschalten

Deaktivieren oder löschen – fertig.

Weniger Phishing und Spam

Deine echte Adresse gibst du nie heraus.

Schon eingebaut:

- **Bitwarden** – Benutzernamen-Generator, auch kostenlos
- **Apple** – „E-Mail-Adresse verbergen“, mit iCloud+
- **Proton Pass** – 10 Aliase in der Gratis-Version

Quellen: [29] Bitwarden-Blog Aliase · [30] Bitwarden-Generator · [31] Proton-Blog Aliase · [32] Apple E-Mail verbergen · [33] Proton Pass Preise

So geht's in Bitwarden

Neuer Eintrag → beim Benutzernamen den Generator öffnen → Typ wählen → übernehmen und speichern.

1 Plus-Adresse

ohne Einrichtung

`max+gsd4aqqe@example.org`

Hängt „+Zufallstext“ an deine Adresse. Die Mail landet im normalen Postfach – wenn dein Anbieter das „+“ unterstützt.

2 Catch-all

eigene Domain nötig

`bqzjlero@meine-domain.example`

Zufällige Adresse unter deiner eigenen Domain. Alles landet im Sammel-Postfach (Catch-all) dieser Domain.

3 Weiterleitungs-Alias

Alias-Dienst nötig

`k7x2p9.d0p0r@relay.example`

Bitwarden legt den Alias per API-Schlüssel automatisch an: SimpleLogin, addy.io, Firefox Relay, DuckDuckGo, Fastmail oder Forward Email.

Gut zu wissen: Klappt mit dem kostenlosen Bitwarden-Konto. Manche Alias-Dienste kosten extra.

Quellen: [29] Bitwarden-Blog Aliase · [30] Bitwarden-Generator

Der zweite Schlüssel: Zwei-Faktor (2FA)

Zum Passwort kommt ein Code vom Handy. Er ändert sich alle 30 Sekunden.



Passwort

etwas, das du weißt

+



Code vom Handy

etwas, das du hast

=



Konto sicher

auch wenn das Passwort geklaut wird

Wie am Geldautomaten: Karte und PIN. Wer nur dein Passwort hat, kommt trotzdem nicht rein.

Quellen: [10] BSI Passwort-Manager · [34] BSI Zwei-Faktor · [35] RFC 6238

Eine freie Authenticator-App wählen

Für die Codes brauchst du eine App. Google und Microsoft haben eigene – es gibt bessere.

Warum weg von Google und Microsoft?

Deine Codes liegen in der Cloud der Konzerne.

Export ist schwer – du sitzt fest.

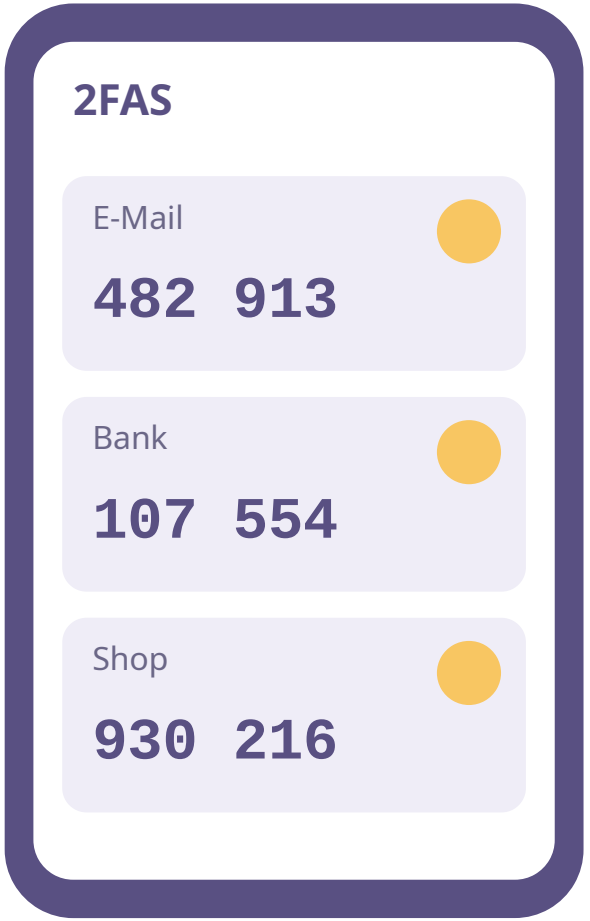
Firmen-Konto? Wenn der Arbeitgeber es verlangt, den Microsoft Authenticator dafür behalten.

2FAS	iPhone, Android, Browser-Erweiterung
Aegis	Android
Ente Auth	alle Geräte, verschlüsselter Abgleich
Proton Authenticator	alle Geräte, Abgleich optional
FreeOTP	iPhone, Android – von Red Hat
Bitwarden Authenticator	iPhone, Android

Quellen: [2] di.day Authenticator · [36] 2FAS Auth · [37] Aegis · [38] Ente Auth · [39] Proton Authenticator · [40] FreeOTP · [41] Bitwarden Authenticator

Beispiel: 2FAS

Die App, die ich selbst nutze – kostenlos, auf mehreren Geräten, mit Backup.



100 % kostenlos

Funktioniert auch offline.

Kein Konto nötig

Anonym nutzbar – ohne Anmeldung.

Offener Quellcode

Open Source (GPL-3.0), einsehbar auf GitHub.

Auf mehreren Geräten

iPhone, Android und Browser – mit Abgleich zwischen Geräten.

Backup direkt in der App

iCloud, Google Drive oder Datei – verschlüsselt, dazu ein eigenes Backup-Passwort.

Quellen: [36] 2FAS Auth · [42] 2FAS Download · [43] 2FAS Backup · [44] 2FAS GitHub

Authenticator wechseln in fünf Schritten

Ruhig angehen: Die alte App erst löschen, wenn alles in der neuen läuft.

1	**Liste machen**	Welche Konten nutzen 2FA? E-Mail, Bank, Shops, Cloud, Social Media.
2	**Notfall-Codes sichern**	Die Wiederherstellungscodes jedes Dienstes ausdrucken oder im Passwortmanager speichern.
3	**Neue App einrichten**	Zum Beispiel 2FAS installieren und mit PIN oder Face ID sperren.
4	**Konten übertragen**	Google: Export per QR-Code. Microsoft: 2FA bei jedem Dienst neu einrichten. Jeden Code testen!
5	**Backup einschalten**	Verschlüsselt und mit starkem Backup-Passwort. Erst dann die alte App löschen.

Quellen: [2] di.day Authenticator

Ausblick: Passkeys

Der nächste Schritt – Anmelden ganz ohne Passwort.



Statt ein Passwort einzutippen, bestätigst du mit Fingerabdruck, Gesicht oder PIN – fertig.

- Kann nicht abgefischt werden – Schutz vor gefälschten Webseiten (Phishing)
- Nichts zu merken, nichts abzutippen
- Wird in iCloud-Schlüsselbund, Google, Bitwarden und Co. gespeichert

Bietet eine Seite Passkeys an? **Ausprobieren!**

Quellen: [2] di.day Authenticator · [14] Apple Passwörter · [45] BSI Passkeys · [46] FIDO Alliance · [47] Google Passkeys · [48] Bitwarden Passkeys

Deine Hausaufgabe

Drei kleine Schritte – mehr braucht es nicht.

Heute

Passwortmanager einschalten

Egal welchen: Browser, Handy oder eigene App.

Diese Woche

E-Mail mit 2FA schützen

Das BSI rät besonders beim E-Mail-Konto zum zweiten Faktor.

Danach

Schritt für Schritt wechseln

Mit den Wechselrezepten von di.day.

Folien, PDF und alle Quellen

bmmmm.github.io/talks/did-passwordmanagers-2026

Wechselrezepte: di.day/de/wechselrezepte

Danke! Fragen?

Quellen: [1] di.day Passwörter · [2] di.day Authenticator · [10] BSI Passwort-Manager · [34] BSI Zwei-Faktor



DEMO TIME!



Quellen: [24] Bitwarden EU-Region · [28] Bitwarden-Konto

Quellen (1/2)

Alle Seiten abgerufen am 27.10.2026 – ein Klick auf einen Eintrag öffnet die Seite.

[1] di.day – Wechselrezept „Passwörter in Deiner Hand“ · di.day

[2] di.day – Wechselrezept „Authenticator“ · di.day

[3] bitcircus101 – offener Hackspace in Bonn · bitcircus101.de

[4] Datenburg e.V. – Bonner Chaostreff und Hackspace · datenburg.org

[5] Hasso-Plattner-Institut – HPI veröffentlicht meist geleakte Passwörter 2025 (26.01.2026, abgerufen am 01.11.2026) · hpi.de

[6] BSI – Sichere Passwörter erstellen · bsi.bund.de

[7] OWASP – Credential Stuffing · community.owasp.org

[8] Have I Been Pwned – Pwned Passwords (Abfrage am 27.10.2026) · haveibeenpwned.com

[9] BSI – Pressemitteilung „Verbesserungsbedarf bei Passwortmanagern“ (09.12.2025) · bsi.bund.de

[10] BSI – Passwörter verwalten mit dem Passwort-Manager · bsi.bund.de

[11] Google Chrome-Hilfe – Passwörter in Chrome verwalten · support.google.com

[12] Mozilla Support – Passwortverwaltung in Firefox · support.mozilla.org

[13] Google-Konto-Hilfe – Kompromittierte Passwörter ändern (Passwortcheck) · support.google.com

[14] Apple Support – Die App „Passwörter“ · support.apple.com

[15] Apple Support – Gespeicherte Passwörter und Passkeys auf dem iPhone · support.apple.com

[16] Microsoft Support – Microsoft Edge geräteübergreifend synchronisieren · support.microsoft.com

[17] Apple Support – Sicherheitsüberblick iCloud-Daten · support.apple.com

[18] Apple Support – iCloud-Passwörter auf dem Windows-Computer einrichten · support.apple.com

[19] Microsoft Support – Kennwortmonitor in Microsoft Edge · support.microsoft.com

[20] Chromium-Dokumentation – Passwortspeicher unter Linux · chromium.googlesource.com

[21] Debian-Manpage – gnome-keyring-daemon · manpages.debian.org

[22] KDE – KWalletManager (Digitale Brieftasche) · apps.kde.org

[23] Bitwarden – Startseite · bitwarden.com

[24] Bitwarden-Hilfe – Server-Regionen (USA und EU) · bitwarden.com

Lizenz: Folien: CC BY 4.0 · Icons: Lucide (ISC), Simple Icons (CC0), Font Awesome Free (CC BY 4.0) · Markenlogos gehören ihren Inhabern.

Quellen (2/2)

Alle Seiten abgerufen am 27.10.2026 – ein Klick auf einen Eintrag öffnet die Seite.

[25] Vaultwarden – selbst gehosteter Bitwarden-kompatibler Server (GitHub) · github.com

[26] KeePassXC – Startseite · keepassxc.org

[27] Proton Pass – Startseite · proton.me

[28] Bitwarden-Hilfe – Bitwarden-Konto erstellen (Server-Standort wählen) · bitwarden.com

[29] Bitwarden-Blog – Forwarded email alias generator (08.04.2026) · bitwarden.com

[30] Bitwarden-Hilfe – Generator (Benutzernamen-Typen) · bitwarden.com

[31] Proton-Blog – Why email aliases are better than fake email addresses · proton.me

[32] Apple Support – „E-Mail-Adresse verbergen“ mit iCloud+ · support.apple.com

[33] Proton Pass – Preise und Pläne · proton.me

[34] BSI – Zwei-Faktor-Authentisierung · bsi.bund.de

[35] RFC 6238 – TOTP, Abschnitt 5.2 (Zeitschritt 30 Sekunden) · rfc-editor.org

[36] 2FAS Auth – Produktseite · 2fas.com

[37] Aegis Authenticator – Startseite · getaegis.app

[38] Ente Auth – Startseite · ente.com

[39] Proton Authenticator – Startseite · proton.me

[40] FreeOTP – Startseite · freeotp.github.io

[41] Bitwarden Authenticator – Produktseite · bitwarden.com

[42] 2FAS – Download · 2fas.com

[43] 2FAS Support – Is 2FAS Auth Backup safe? · 2fas.com

[44] 2FAS – Quellcode auf GitHub · github.com

[45] BSI – Passkeys: Anmelden ohne Passwort · bsi.bund.de

[46] FIDO Alliance – Passkeys · fidoalliance.org

[47] Google Chrome-Hilfe – Passkeys in Chrome verwalten · support.google.com

[48] Bitwarden-Hilfe – Passkeys speichern · bitwarden.com

Lizenz: Folien: CC BY 4.0 · Icons: Lucide (ISC), Simple Icons (CC0), Font Awesome Free (CC BY 4.0) · Markenlogos gehören ihren Inhabern.